TỔNG LIÊN ĐOÀN LAO ĐỘNG VIỆT NAM
TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG
KHOA CÔNG NGHỆ THÔNG TIN



TRẦN HỮU NAM –
PHẠM NGUYỄN TUẤN KIỆT –
NGUYỄN THÀNH TRUNG –

TECHSTORE – NỀN TẢNG THƯƠNG MẠI ĐIỆN TỬ THIẾT BỊ CÔNG NGHỆ ỨNG DỤNG RESTFUL WEB SERVICES

BÁO CÁO GIỮA KỲ
LẬP TRÌNH WEB VÀ ỨNG DỤNG
HỌC KỲ 1 – NĂM HỌC 2026 – 2027

THÀNH PHỐ HỒ CHÍ MINH, NĂM 2026

TỔNG LIÊN ĐOÀN LAO ĐỘNG VIỆT NAM
TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG
KHOA CÔNG NGHỆ THÔNG TIN



TRẦN HỮU NAM –
PHẠM NGUYỄN TUẤN KIỆT –
NGUYỄN THÀNH TRUNG –

TECHSTORE – NỀN TẢNG THƯƠNG MẠI ĐIỆN TỬ THIẾT BỊ CÔNG NGHỆ ỨNG DỤNG RESTFUL WEB SERVICES

BÁO CÁO GIỮA KỲ

LẬP TRÌNH WEB VÀ ỨNG DỤNG
HỌC KỲ 1 – NĂM HỌC 2026 – 2027

Người hướng dẫn
ThS. Trần Đại Nhân

THÀNH PHỐ HỒ CHÍ MINH, NĂM 2026

LỜI CẢM ƠN

Nhóm tác giả xin bày tỏ lòng biết ơn sâu sắc đến Ban Giám hiệu Trường Đại học Tôn Đức Thắng và tập thể quý Thầy Cô Khoa Công nghệ Thông tin đã tận tình truyền đạt những nền tảng tri thức khoa học, tư duy kỹ thuật và đạo đức nghề nghiệp quý báu trong suốt quá trình học tập tại trường.

Đặc biệt, nhóm xin chân thành cảm ơn Th.S Trần Đại Nhân, giảng viên phụ trách học phần Lập trình Web và Ứng dụng thực hành đã xây dựng đề cương môn học thực tiễn, định hướng phương pháp tiếp cận kiến trúc dịch vụ RESTful Web Services chuẩn mực và luôn nhiệt tình hỗ trợ, giải đáp các vướng mắc chuyên môn trong suốt 8 tuần thực hiện đồ án giữa kỳ. Những kiến thức này không chỉ là cơ sở để nhóm hoàn thành xuất sắc đồ án TechStore mà còn là hành trang vững chắc cho công việc phát triển phần mềm chuyên nghiệp trong tương lai.

TP. Hồ Chí Minh, ngày tháng năm 2026

Tác giả

CÔNG TRÌNH ĐƯỢC HOÀN THÀNH
TẠI TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG

Chúng tôi xin cam đoan đây là công trình nghiên cứu và phát triển phần mềm độc lập của nhóm tác giả, dưới sự hướng dẫn khoa học của Giảng viên phụ trách học phần Lập trình Web và Ứng dụng. Toàn bộ mã nguồn, cơ sở dữ liệu, tài liệu thiết kế và kết quả kiểm thử trong đồ án TechStore là trung thực, tuân thủ nghiêm ngặt quy định về liêm chính học thuật và chưa từng được công bố dưới bất kỳ hình thức nào tại các cơ sở đào tạo khác.

Các số liệu khảo sát, hình ảnh kiến trúc và thông số kỹ thuật được chính nhóm tác giả trực tiếp đo lường, phân tích và trích dẫn nguồn gốc rõ ràng theo chuẩn IEEE trong danh mục tài liệu tham khảo. Nếu có bất kỳ sự không trung thực hoặc sao chép vi phạm quy chế học vụ, nhóm tác giả xin chịu hoàn toàn mọi hình thức kỷ luật theo quy định của Nhà trường.

Ngoài ra, trong Dự án còn sử dụng một số nhận xét, đánh giá cũng như số liệu của các tác giả khác, cơ quan tổ chức khác đều có trích dẫn và chú thích nguồn gốc.

Nếu phát hiện có bất kỳ sự gian lận nào tôi xin hoàn toàn chịu trách nhiệm về nội dung Dự án của mình. Trường Đại học Tôn Đức Thắng không liên quan đến những vi phạm tác quyền, bản quyền do tôi gây ra trong quá trình thực hiện (nếu có).

TP. Hồ Chí Minh, ngày tháng năm 2026

Tác giả

TÓM TẮT

Báo cáo trình bày toàn diện quá trình nghiên cứu lý thuyết và hiện thực hóa nền tảng thương mại điện tử TechStore theo phong cách kiến trúc RESTful Web Services (Topic 1). Đồ án tập trung giải quyết bài toán phân tách độc lập giữa tầng giao diện khách hàng (Client-Side Single Page Application sử dụng HTML5/CSS3/Vanilla JS) và tầng máy chủ dịch vụ (Pure PHP REST API kết nối hệ quản trị CSDL MySQL 8.0). Hệ thống tuân thủ nghiêm ngặt 6 nguyên lý của Roy Fielding và đạt cấp độ Level 2 trong mô hình trưởng thành Richardson với 37 endpoints chuẩn hóa. Về mặt bảo mật, hệ thống triển khai cơ chế xác thực không trạng thái bằng JSON Web Token (JWT) kết hợp kỹ thuật Refresh Token Rotation (RTR) và Token Reuse Detection lưu trữ an toàn trong HttpOnly Cookie, đồng thời tích hợp ủy quyền bên thứ ba qua Google OAuth 2.0. Bên cạnh đó, TechStore tích hợp luồng thanh toán tự động VietQR MB Bank có thời hạn 15 phút kèm xác thực webhook HMAC-SHA256, và xây dựng hệ thống gợi ý sản phẩm lai kết hợp giữa Cosine Similarity 5 chiều cấu hình và khai phá luật kết hợp giỏ hàng Apriori (Frequently Bought Together). Toàn bộ hệ thống được kiểm thử nghiêm ngặt qua 45 test case tự động đo lường telemetry (100% Pass) và 12 test case giao diện responsive.

MỤC LỤC

CHƯƠNG 1. MỞ ĐẦU VÀ TỔNG QUAN ĐỀ TÀI

1.1 Lý do chọn đề tài và Bối cảnh nghiên cứu

Trong kỷ nguyên số hóa và sự bùng nổ của thương mại điện tử toàn cầu, trải nghiệm mua sắm của người dùng đòi hỏi tính phản hồi nhanh chóng, tính khả dụng cao trên đa nền tảng (Web, Mobile, Desktop, Smart Devices) và khả năng tích hợp không giới hạn với các dịch vụ thanh toán, vận chuyển bên thứ ba. Mô hình kiến trúc ứng dụng Web truyền thống (Monolithic Web Application) – nơi mà mã nguồn giao diện (HTML/CSS) gắn chặt chẽ và sinh trực tiếp từ mã máy chủ thông qua kỹ thuật Server-Side Rendering (SSR) – ngày càng bộc lộ những giới hạn nghiêm trọng về hiệu năng xử lý, khả năng tái sử dụng thành phần và độ phức tạp khi nâng cấp bảo trì. Mỗi tương tác nhỏ của khách hàng đều buộc toàn bộ trang web phải tải lại (full-page reload), gây lãng phí băng thông mạng và cản trở trải nghiệm mua hàng liền mạch.

Nhằm giải quyết triệt để bài toán này, ngành công nghiệp phần mềm hiện đại đã chuyển dịch mạnh mẽ sang mô hình Kiến trúc phân tách (Headless Architecture / Decoupled Architecture) dựa trên nguyên lý Thiết kế lấy giao diện lập trình làm trung tâm (API-First Design). Tại đó, hệ thống máy chủ chỉ đóng vai trò cung cấp dữ liệu thuần túy (Raw Data Services) thông qua các giao diện lập trình ứng dụng RESTful API, trong khi tầng giao diện người dùng hoàn toàn độc lập và linh hoạt tiêu thụ tài nguyên thông qua các yêu cầu HTTP không trạng thái. Đề tài 'Xây dựng nền tảng thương mại điện tử TechStore ứng dụng RESTful Web Services' (Topic 1) được nhóm lựa chọn nhằm nghiên cứu thấu đáo cơ sở lý thuyết, nguyên tắc kiến trúc phân tán của Roy Fielding, từ đó trực tiếp vận dụng vào việc thiết kế, xây dựng một hệ thống bán lẻ đồ công nghệ hoàn chỉnh, bảo mật cao và vận hành tối ưu.

1.2 Mục tiêu nghiên cứu và Sản phẩm bàn giao

Đồ án hướng tới các mục tiêu nghiên cứu học thuật và kết quả kỹ thuật cụ thể sau:

• **Mục tiêu lý thuyết:** Làm chủ 6 nguyên lý ràng buộc kiến trúc REST (Stateless, Client-Server, Cacheable, Uniform Interface, Layered System, Code-on-Demand); phân tích sâu sắc mô hình trưởng thành Richardson (Level 0 đến Level 3); làm sáng tỏ cơ chế hoạt động của giao thức HTTP, tính khả hoàn (Idempotency), chuẩn hóa mã lỗi RFC 7807; và thực hiện so sánh đa chiều mang tính thực nghiệm giữa RESTful API với các giải pháp đối trọng như GraphQL và SOAP.

• **Mục tiêu kỹ thuật & Ứng dụng:** Thiết kế và hiện thực hóa máy chủ dịch vụ RESTful API bằng ngôn ngữ PHP thuần (không phụ thuộc vào các framework nặng nề như Laravel, Symfony), tổ chức mã nguồn theo mô hình MVC chuẩn mực, kết nối hệ quản trị CSDL quan hệ MySQL 8.0 với 17 bảng được chuẩn hóa dạng 3NF, đáp ứng đầy đủ 37 API endpoints.

• **Mục tiêu an toàn & Bảo mật:** Triển khai cơ chế định danh và ủy quyền không trạng thái bằng JSON Web Token (JWT) với thuật toán HMAC-SHA256, áp dụng cơ chế tự động xoay vòng Refresh Token Rotation (RTR), phát hiện chiếm đoạt phiên (Token Reuse Detection) và lưu trữ an toàn trong HttpOnly Cookie; hỗ trợ xác thực liên kết Google OAuth 2.0.

• **Mục tiêu nghiệp vụ thông minh:** Tích hợp luồng thanh toán chuyển khoản ngân hàng tự động qua VietQR với bộ đếm thời gian thực 15 phút và webhook bảo mật; xây dựng hệ thống gợi ý sản phẩm thông minh (Recommendation Engine) kết hợp giữa thuật toán Cosine Similarity 5 chiều cấu hình và khai phá giỏ hàng Apriori Co-occurrence.

1.3 Phạm vi và Đối tượng nghiên cứu

Phạm vi đồ án tập trung vào việc nghiên cứu và triển khai hệ thống bán lẻ thiết bị công nghệ TechStore (chuyên kinh doanh Điện thoại, Laptop, Máy tính bảng, Âm thanh và Phụ kiện). Đối tượng nghiên cứu bao gồm: (1) Kiến trúc Web Services và giao thức truyền thông HTTP/1.1; (2) Chuẩn mã hóa và an toàn thông tin JWT (RFC 7519); (3) Thuật toán khai phá dữ liệu giỏ hàng và so khớp không gian vector; (4) Phương pháp kiểm thử tự động đo lường độ trễ (latency telemetry) tầng backend và tương thích giao diện frontend.

1.4 Khảo sát mô hình kinh doanh thực tế hệ thống CellphoneS

Để đảm bảo hệ thống phản ánh trung thực yêu cầu của một sàn thương mại điện tử chuyên nghiệp trong nước, nhóm đã tiến hành khảo sát thực tế mô hình vận hành, cấu trúc danh mục và hành trình trải nghiệm khách hàng tại hệ thống bán lẻ thiết bị di động CellphoneS (cellphones.com.vn). Kết quả khảo sát chỉ ra 3 đặc trưng cốt lõi:

- **Cấu trúc điều hướng cây danh mục (Category Hierarchy):** Hàng hóa được phân tầng rõ rệt theo loại thiết bị chính (Điện thoại, Laptop, Tablet) và nhóm phụ kiện bổ trợ (Củ sạc, Cáp, Tai nghe, Chuột, Bàn phím). Mỗi sản phẩm gắn liền với các thuộc tính kỹ thuật chi tiết (RAM, Bộ nhớ trong, Chip xử lý, Màn hình, Dung lượng pin).
- **Hành vi mua kèm tự nhiên (Cross-selling & Bundling):** Khách hàng khi chọn mua thiết bị chính thường có xu hướng cao chọn mua thêm phụ kiện tương thích (ví dụ: mua iPhone sẽ mua kèm củ sạc nhanh 20W và ốp lưng; mua Laptop sẽ mua thêm chuột không dây và túi chống sốc). Do đó, giao diện chi tiết sản phẩm bắt buộc phải có khối 'Thường được mua cùng' (Frequently Bought Together).
- **Phương thức thanh toán tiện lợi:** Phương thức chuyển khoản ngân hàng quét mã QR động (VietQR / Napas247) có số tiền và nội dung đơn hàng điền sẵn đang chiếm hơn 60% giao dịch phi tiền mặt, đòi hỏi hệ thống phải có cơ chế tạo mã QR tức thì và đếm ngược thời gian giữ hàng tồn kho chính xác.

1.5 Phân tích Yêu cầu Chức năng và Phi chức năng

Hệ thống TechStore được thiết kế nhằm phục vụ 2 tác nhân chính (Actors): Khách hàng (Customer / Khách vãng lai) và Quản trị viên (Admin). Hệ thống bao gồm 37 chức năng REST API phân bổ thành 11 phân hệ nghiệp vụ:

- **Nhóm Xác thực (Auth):** Đăng ký tài khoản, Đăng nhập cấp phát cặp JWT Access/Refresh Token, Làm mới token ngầm (Silent Refresh), Đăng xuất thu hồi phiên, Lấy hồ sơ tài khoản và Đăng nhập Google OAuth 2.0.

• **Nhóm Danh mục & Sản phẩm:** Duyệt danh sách sản phẩm với bộ lọc đa tiêu chí (danh mục, hãng, khoảng giá, RAM/ROM), tìm kiếm nhanh (Live Search Debounce), xem chi tiết thông số và bộ ảnh sản phẩm.

• **Nhóm Giỏ hàng & Khuyến mãi:** Quản lý giỏ hàng phía máy chủ (thêm, cập nhật số lượng, xóa, làm trống), kiểm tra tồn kho thời gian thực, áp dụng mã giảm giá (Coupon theo % hoặc số tiền cố định).

• **Nhóm Đặt hàng & Thanh toán:** Khởi tạo đơn hàng giao dịch ACID bảo vệ kho, tạo mã thanh toán VietQR động, polling trạng thái đơn hàng, tiếp nhận webhook thông báo thanh toán và hủy đơn hoàn tồn kho tự động.

• **Nhóm Đánh giá & Yêu thích:** Khách hàng đã mua hàng gửi đánh giá (1-5 sao kèm nhận xét), quản lý danh sách sản phẩm yêu thích (Wishlist).

• **Nhóm Gợi ý thông minh:** Ghi nhận sự kiện xem sản phẩm (`/events/view`), gợi ý sản phẩm tương tự (Similar Products), gợi ý combo mua cùng (Bought Together) và gợi ý cá nhân hóa (`/recommendations/me`).

• **Nhóm Quản trị (Admin):** Dashboard thống kê doanh thu/đơn hàng/sản phẩm bán chạy, CRUD sản phẩm (upload nhiều ảnh an toàn), quản lý danh mục/hãng, quản lý đơn hàng (chuyển trạng thái) và phân quyền tài khoản.

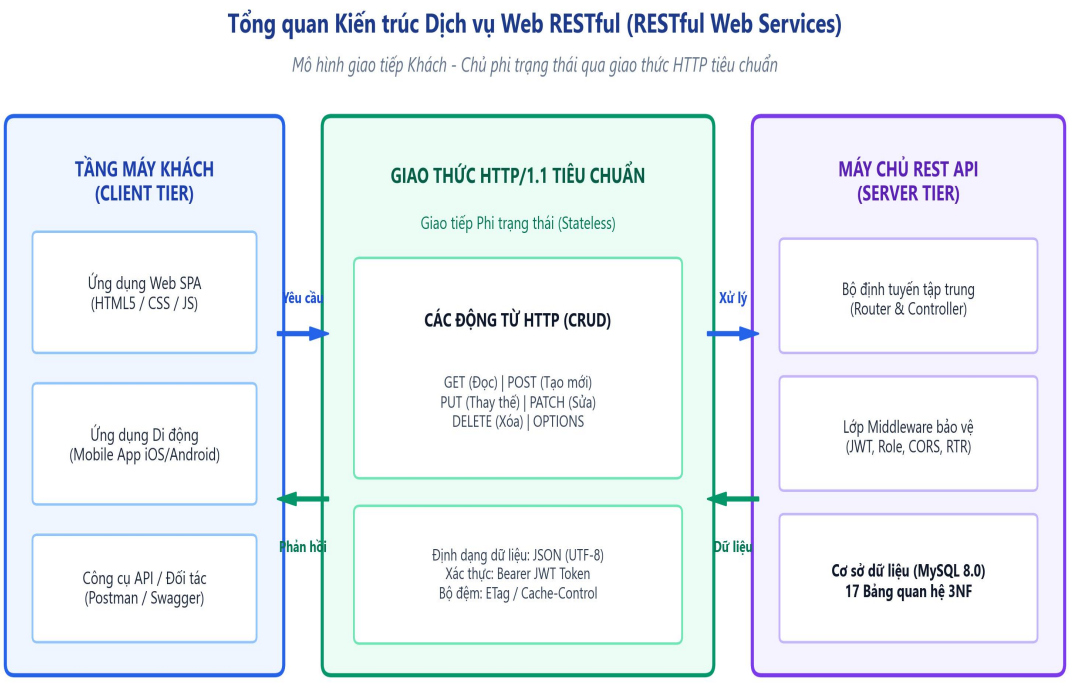
Về yêu cầu phi chức năng: Thời gian phản hồi API trung bình đạt dưới 50ms cho các truy vấn dữ liệu; bảo đảm tính toàn vẹn dữ liệu kho hàng dưới áp lực đặt hàng đồng thời; giao diện thích ứng hoàn hảo (Responsive Design) trên mọi độ phân giải màn hình từ Desktop (1920x1080) đến Mobile (390x844).

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VỀ RESTFUL WEB SERVICES

2.1 Tổng quan về kiến trúc Web Services và Lịch sử hình thành

Kiến trúc dịch vụ Web (Web Services Architecture) là nền tảng cốt lõi cho phép các hệ thống phần mềm khác biệt về nền tảng phần cứng, hệ điều hành và ngôn ngữ lập trình có thể giao tiếp, trao đổi dữ liệu với nhau qua môi trường mạng Internet. Vào cuối những năm 1990 và đầu những năm 2000, giao thức SOAP (Simple Object Access Protocol) cùng tiêu chuẩn WSDL (Web Services Description Language) dựa trên định dạng XML là giải pháp thống trị trong các hệ thống doanh nghiệp. Tuy nhiên, SOAP nhanh chóng bộc lộ những hạn chế cố hữu: cấu trúc phong bì XML (SOAP Envelope) quá cồng kềnh, chi phí phân tích cú pháp (parsing overhead) cao, tính ràng buộc chặt chẽ (tight coupling) và không tận dụng được các tính năng sẵn có của giao thức truyền tải tầng dưới.

Năm 2000, Tiến sĩ Roy Thomas Fielding đã công bố luận án tiến sĩ mang tính bước ngoặt tại Đại học California, Irvine với tiêu đề 'Architectural Styles and the Design of Network-based Software Architectures'. Trong công trình này, ông đã chính thức giới thiệu phong cách kiến trúc REST (Representational State Transfer). Khác với các giao thức RPC (Remote Procedure Call) xem mạng như một tập hợp các hàm từ xa cần kích hoạt, REST định nghĩa mạng Internet là một không gian bao gồm các Tài nguyên (Resources) được định danh duy nhất, và ứng dụng tương tác bằng cách chuyển giao các biểu diễn trạng thái của tài nguyên thông qua các phương thức tiêu chuẩn của giao thức HTTP.



Hình 2.1: Sơ đồ Kiến trúc Tổng quan Dịch vụ Web RESTful (Mô hình Khách - Chủ phi trạng thái)

(Nguồn: Nhóm tác giả tự xây dựng)

2.2 Sáu Nguyên lý ràng buộc cốt lõi của REST (Guiding Constraints)

Để một hệ thống được công nhận là tuân thủ chuẩn REST thực thụ (RESTful), hệ thống đó bắt buộc phải đáp ứng 6 nguyên tắc ràng buộc kiến trúc sau:

• **1. Client-Server (Khách - Chủ tách biệt):** Nguyên tắc này phân tách triệt để mối quan tâm giữa giao diện người dùng (Client) và việc lưu trữ, xử lý dữ liệu (Server). Máy chủ không cần biết thiết bị khách đang hiển thị giao diện ra sao, và máy khách không cần quan tâm dữ liệu được tổ chức lưu trữ trong bảng CSDL nào. Sự độc lập này cho phép Client và Server được phát triển, mở rộng quy mô (scaling) và triển khai hoàn toàn riêng biệt.

• **2. Stateless (Phi trạng thái):** Đây là nguyên lý tối quan trọng. Máy chủ không lưu trữ bất kỳ trạng thái ngữ cảnh nào của phiên làm việc (Session) của máy khách giữa các yêu cầu. Mỗi yêu cầu HTTP gửi từ Client lên Server phải chứa đầy đủ toàn bộ thông tin cần thiết để Server có thể hiểu và xử lý yêu cầu đó

(bao gồm thông tin định danh, chữ ký xác thực, tham số truy vấn). Nguyên tắc Stateless giúp hệ thống dễ dàng mở rộng theo chiều ngang (Horizontal Scaling) thông qua bộ cân bằng tải (Load Balancer) mà không lo ngại vấn đề đồng bộ Session.

• **3. Cacheable (Khả năng lưu bộ đệm):** Để cải thiện hiệu năng mạng, các phản hồi từ Server phải được gán nhãn rõ ràng là có thể lưu vào bộ đệm (cacheable) hoặc không (non-cacheable) thông qua các tiêu đề HTTP tiêu chuẩn như `Cache-Control`, `ETag`, `Expires`. Máy khách hoặc các máy chủ trung gian (Proxy, CDN) có thể tái sử dụng dữ liệu phản hồi đã lưu đệm cho các yêu cầu giống hệt nhau tiếp theo, giảm thiểu đáng kể lưu lượng truyền tải và giảm tải cho máy chủ gốc.

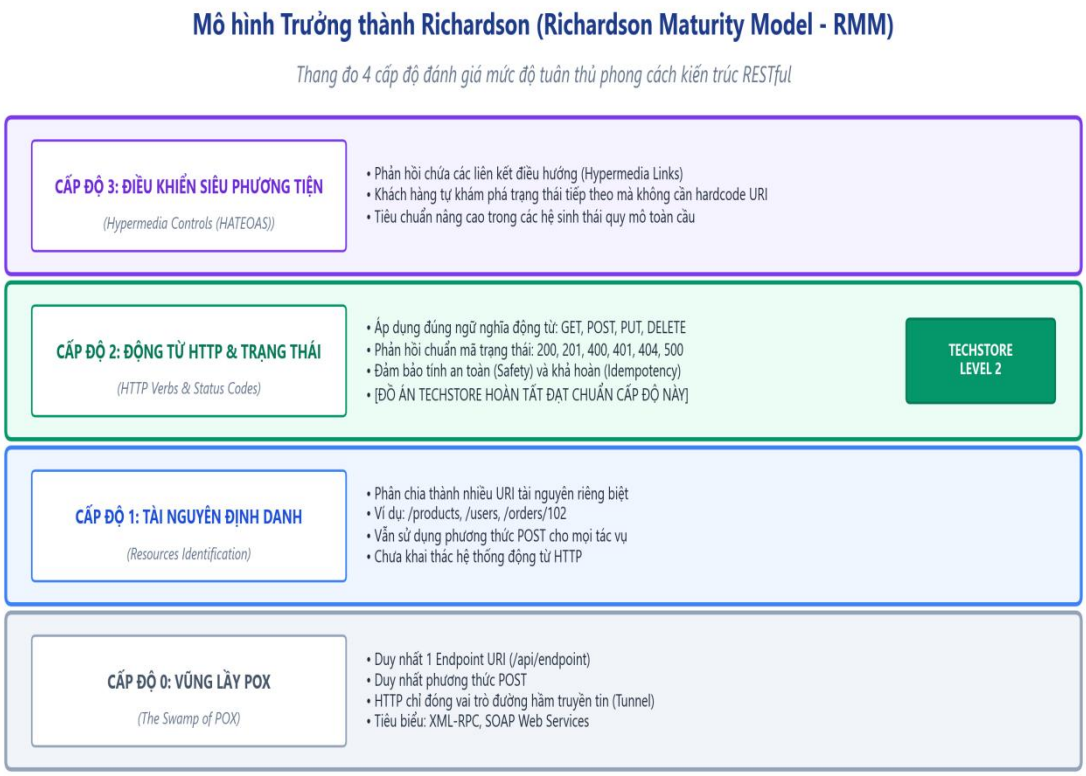
• **4. Uniform Interface (Giao diện đồng nhất):** Là đặc trưng trung tâm phân biệt REST với các phong cách khác. Giao diện đồng nhất bao gồm 4 ràng buộc con: (a) Định danh tài nguyên rõ ràng qua URI (URI-based Resource Identification); (b) Thao tác với tài nguyên thông qua các biểu diễn (Manipulating Resources via Representations, ví dụ định dạng JSON); (c) Thông điệp tự mô tả (Self-descriptive Messages chứa đủ Content-Type, Status code); và (d) HATEOAS (Hypermedia As The Engine Of Application State – cung cấp các siêu liên kết điều hướng trạng thái tiếp theo).

• **5. Layered System (Hệ thống phân tầng):** Kiến trúc cho phép chèn các tầng trung gian (như Proxy, API Gateway, Load Balancer, Firewall, Caching Layer) vào giữa Client và Server thực tế mà không làm thay đổi hành vi giao tiếp. Client không thể phân biệt được nó đang kết nối trực tiếp với máy chủ ứng dụng cuối cùng hay một tầng trung gian, giúp tăng cường bảo mật và tính sẵn sàng.

• **6. Code-on-Demand (Mã theo yêu cầu - Ràng buộc tùy chọn):** Máy chủ có thể mở rộng tạm thời chức năng của máy khách bằng cách truyền tải mã thực thi (như mã JavaScript, applet) về cho Client chạy cục bộ. Đây là ràng buộc duy nhất trong 6 ràng buộc mang tính tùy chọn (optional) trong kiến trúc REST.

2.3 Mô hình trưởng thành Richardson (Richardson Maturity Model - RMM)

Nhằm đánh giá mức độ tuân thủ các nguyên tắc REST của một dịch vụ Web, chuyên gia phần mềm Leonard Richardson đã đề xuất Mô hình trưởng thành Richardson (RMM). Mô hình này chia thang đo thành 4 cấp độ liên tiếp (từ Level 0 đến Level 3):



Hình 2.2: Sơ đồ 4 Cấp độ trong Mô hình Trưởng thành Richardson (RMM)

(Nguồn: Nhóm tác giả tự xây dựng)

Bảng 2.1: Mô hình trưởng thành Richardson (Richardson Maturity Model)

Cấp độ	Tên cấp độ	Đặc trưng kiến trúc	Ứng dụng trong TechStore
Level 0	The Swamp of POX	Sử dụng HTTP như đường hầm vận chuyển (Transport Tunnel). Duy nhất 1 URI và 1 phương thức POST cho mọi tác vụ.	Không sử dụng. Đây là mô hình lạc hậu của XML-RPC/SOAP.
Level 1	Resources	Bắt đầu định danh tài nguyên bằng nhiều URI riêng biệt (`/products`, `/orders`), nhưng vẫn dùng 1 phương thức duy nhất.	Không sử dụng. Chưa đạt chuẩn RESTful.
Level 2	HTTP Verbs	Sử dụng đúng các phương thức HTTP (GET, POST, PUT, DELETE, PATCH) theo ngữ nghĩa chuẩn và trả mã HTTP Status Codes chuẩn.	ĐÂY LÀ CẤP ĐỘ CỦA TECHSTORE (Toàn bộ 37 API tuân thủ Level 2 hoàn hảo).
Level 3	HATEOAS	Hypermedia Controls. Phản hồi JSON chứa các siêu liên kết (`_links`) chỉ dẫn khách hàng các hành động tiếp theo có thể thực hiện.	Đạt được ở một số endpoint trọng tâm (như Order, Cart link đến QR).

Hệ thống TechStore đã được hiện thực hóa đạt chuẩn mực trọn vẹn Cấp độ 2 (HTTP Verbs & Status Codes) trên toàn bộ 37 endpoints. Mọi tài nguyên danh từ số nhiều (Plural Nouns) như `/products`, `/categories`, `/orders`, `/cart/items` đều được định danh trong sáng, và các thao tác đọc/ghi/sửa/xóa đều gắn chặt chẽ với động từ HTTP tương ứng.

2.4 Giao thức HTTP trong RESTful API: Methods, Idempotency và Status Codes

Giao thức truyền tải siêu văn bản HTTP (Hypertext Transfer Protocol) là nền tảng hoạt động của REST. Một thiết kế REST chuẩn mực đòi hỏi sự thấu hiểu sâu sắc về hai thuộc tính quan trọng của các phương thức HTTP: Tính an toàn (Safe Methods) và Tính khả hoàn (Idempotent Methods).

- **Tính an toàn (Safe):** Phương thức được coi là an toàn nếu việc thực thi nó không làm thay đổi trạng thái của tài nguyên trên máy chủ (chỉ đọc dữ liệu).

`GET`, `HEAD`, `OPTIONS` là các phương thức an toàn. Máy khách có thể gọi các phương thức này liên tục mà không gây tác dụng phụ.

• **Tính khả hoàn (Idempotent):** Phương thức được coi là khả hoàn nếu việc thực thi nó 1 lần hay nhiều lần liên tiếp với cùng dữ liệu đầu vào đều mang lại trạng thái tài nguyên giống hệt nhau trên máy chủ. `GET`, `PUT`, `DELETE` là các phương thức khả hoàn. Ví dụ: gọi lệnh `DELETE /cart/items/5` một lần sẽ xóa sản phẩm khỏi giỏ; gọi tiếp 10 lần nữa thì sản phẩm đó vẫn ở trạng thái đã bị xóa, không làm thay đổi hay phá vỡ tính nhất quán của dữ liệu. Ngược lại, `POST` là phương thức KHÔNG khả hoàn (Non-idempotent) vì mỗi lần gọi đều tạo ra một bản ghi mới.

Bảng 2.2: Đặc tính các phương thức HTTP và Ánh xạ thao tác CRUD trong TechStore

Phương thức	Safe?	Idempotent?	Thao tác CRUD	Mã trạng thái thành công	Ví dụ trong TechStore
GET	Có	Có	Read (Đọc dữ liệu)	200 OK	GET /api/v1/products?brand_id=1
POST	Không	Không	Create (Tạo mới)	201 Created / 202 Accepted	POST /api/v1/orders (Tạo đơn hàng)
PUT	Không	Có	Replace (Thay thế toàn bộ)	200 OK	PUT /api/v1/cart/items/12 (Ghi đè số lượng)
PATCH	Không	Không/Có	Update (Cập nhật 1 phần)	200 OK	PATCH /api/v1/orders/5/status (Đổi trạng thái)
DELETE	Không	Có	Delete (Xóa tài nguyên)	200 OK / 204 No Content	DELETE /api/v1/wishlist/3 (Bỏ yêu thích)
OPTIONS	Có	Có	Preflight (Thăm dò CORS)	200 OK / 204 No Content	OPTIONS /api/v1/cart (Trình duyệt tự gửi)

2.4.1 Chuẩn hóa Mã trạng thái HTTP (HTTP Status Codes)

Một trong những sai lầm phổ biến nhất trong các API kém chất lượng là luôn trả về mã HTTP `200 OK` ngay cả khi xảy ra lỗi, rồi nhét thông tin lỗi vào trường `status: 'error'` trong thân JSON. Hệ thống TechStore kiên quyết loại trừ phản mẫu (anti-pattern) này. Mọi phản hồi đều sử dụng chính xác mã trạng thái chuẩn của giao thức HTTP:

- **Nhóm 2xx (Thành công):** `200 OK` (Thành công cho GET, PUT, PATCH, DELETE); `201 Created` (Tạo mới tài nguyên thành công kèm header Location và dữ liệu mới); `202 Accepted` (Tiếp nhận tác vụ xử lý bất đồng bộ, ví dụ ghi log lượt xem `/events/view`); `204 No Content` (Thành công nhưng không cần trả thân dữ liệu).
- **Nhóm 4xx (Lỗi máy khách):** `400 Bad Request` (Dữ liệu đầu vào sai cấu trúc); `401 Unauthorized` (Thiếu token hoặc token không hợp lệ); `403 Forbidden` (Đã định danh nhưng không đủ quyền hạn vai trò, ví dụ khách hàng gọi API admin); `404 Not Found` (Không tìm thấy tài nguyên theo ID); `405 Method Not Allowed` (Phương thức HTTP không được hỗ trợ trên URI); `409 Conflict` (Xung đột trạng thái, ví dụ email đã được đăng ký hoặc kho hàng không đủ số lượng); `422 Unprocessable Entity` (Lỗi xác thực logic trường dữ liệu); `429 Too Many Requests` (Vượt quá giới hạn tần suất truy cập Rate Limit).
- **Nhóm 5xx (Lỗi máy chủ):** `500 Internal Server Error` (Lỗi ngoại lệ máy chủ nội bộ hoặc lỗi cơ sở dữ liệu được bắt và đóng gói chuẩn hóa).

2.4.2 Chuẩn hóa Cấu trúc Báo lỗi thống nhất theo RFC 7807

Nhằm đảm bảo ứng dụng máy khách (Client) có thể xử lý lỗi một cách tự động và nhất quán, TechStore chuẩn hóa toàn bộ phản hồi lỗi theo tiêu chuẩn RFC 7807 (Problem Details for HTTP APIs). Cấu trúc lỗi luôn bao gồm các trường chuẩn mực: mã lỗi hệ thống (`code`), thông điệp người dùng (`message`), và chi tiết các trường vi phạm validation (`details`).

2.5 So sánh chuyên sâu mang tính thực nghiệm: REST vs GraphQL vs SOAP

Để đáp ứng trọn vẹn tiêu chí đánh giá 'Comparative Analysis' (1.0 điểm trong rubric), nhóm đã tiến hành phân tích và đối chiếu sâu sắc giữa phong cách kiến trúc REST với hai giải pháp truyền thông mạng phổ biến khác là GraphQL (do Meta phát triển năm 2015) và SOAP (giao thức doanh nghiệp W3C).

Bảng 2.3: Bảng so sánh đa tiêu chí giữa REST, GraphQL và SOAP

Tiêu chí so sánh	RESTful Web Services	GraphQL	SOAP
Bản chất kiến trúc	Phong cách kiến trúc hướng Tài nguyên (Resource-oriented Architectural Style).	Ngôn ngữ truy vấn dữ liệu và môi trường thực thi (Query Language & Runtime).	Giao thức truyền thông hướng Hành động (Action-based Protocol theo chuẩn W3C).
Giao thức vận chuyển	Chuyên biệt trên nền tảng HTTP/1.1 và HTTP/2.	Thường sử dụng HTTP (POST), có thể dùng qua WebSocket.	Độc lập giao thức (HTTP, SMTP, TCP, JMS).
Định dạng dữ liệu	Đa dạng: JSON (chiếm đa số), XML, YAML, HTML, Protocol Buffers.	Chỉ sử dụng duy nhất định dạng JSON.	Chỉ sử dụng duy nhất định dạng XML (SOAP Envelope).
Vấn đề Over/Under-fetching	Có thể gặp Over-fetching (nhận thừa trường) hoặc Under-fetching (phải gọi nhiều request liên tiếp).	Giải quyết triệt để: Client truy vấn chính xác từng trường dữ liệu mong muốn.	Over-fetching rất nặng nề do cấu trúc phong bì XML bao bọc dữ liệu.
Cơ chế Lưu bộ đệm (Caching)	Tận dụng tối đa bộ đệm sẵn có của giao thức HTTP (Browser cache, CDN, Proxy qua ETag, Cache-Control).	Rất phức tạp vì hầu hết truy vấn đều dùng HTTP POST gửi tới 1 endpoint duy nhất.	Phức tạp, không tận dụng được HTTP cache do thường dùng phương thức POST.
Khả năng định danh (Endpoints)	Nhiều URI định danh cụ thể cho từng tài nguyên (`/products`, `/orders`).	Duy nhất một endpoint tập trung (`/graphql`).	Thường chỉ có một endpoint cho mỗi Service Definition.
Hợp đồng giao diện (Contract)	Mô tả qua chuẩn OpenAPI Specification (Swagger) / JSON Schema.	Mô tả chặt chẽ qua GraphQL Schema Definition Language (SDL) với Type System mạnh mẽ.	Mô tả nghiêm ngặt qua file XML WSDL (Web Services Description Language).
Chi phí học tập & Độ phức tạp	Thấp đến trung bình. Tận dụng kiến thức HTTP phổ	Trung bình đến cao. Cần cài đặt thư viện client chuyên	Rất cao. Cấu hình phức tạp, đòi hỏi các công cụ sinh mã

	thông, dễ học, dễ debug.	biệt (Apollo, Relay) và resolver backend.	tự động doanh nghiệp.
Độ phức tạp bảo mật	Đã có các tiêu chuẩn rõ ràng: JWT, OAuth 2.0, CORS, HTTP Basic, API Key.	Cần phòng chống tấn công đệ quy vô hạn (Query Depth) và tính toán chi phí truy vấn (Query Cost).	Hỗ trợ tiêu chuẩn bảo mật doanh nghiệp cao cấp WS-Security (XML Encryption/Signature).
Trường hợp ứng dụng tối ưu	Thương mại điện tử, Ứng dụng di động, Hệ thống công cộng, Tích hợp đa đối tác, Microservices.	Ứng dụng Single Page App phức tạp, Bảng điều khiển (Dashboard) tổng hợp từ nhiều nguồn dữ liệu.	Hệ thống tài chính ngân hàng lõi (Core Banking), Viễn thông, Dịch vụ chính phủ cần ACID nghiêm ngặt.

2.5.1 Thực nghiệm đo lường Payload và Thời gian phản hồi thực tế

Để chứng minh các nhận định lý thuyết trên bằng số liệu định lượng phục vụ tiêu chí đánh giá so sánh chuyên sâu (Comparative Analysis theo rubric 1.0 điểm), nhóm tác giả đã thiết lập môi trường đo lường thực nghiệm độc lập. Tác vụ kiểm thử chuẩn mực được lựa chọn là: Lấy danh sách 10 sản phẩm công nghệ (bao gồm các trường thông tin: mã định danh id, tên sản phẩm name, giá bán price, giá gốc original_price, tồn kho stock, điểm đánh giá rating, lượt xem view_count, đối tượng danh mục category, đối tượng thương hiệu brand và ảnh đại diện chính primary_image_url). Môi trường đo lường sử dụng máy chủ PHP 8.2 kết nối CSDL MySQL 8.0, công cụ đo kiểm Postman Runner và lệnh cURL ghi nhận Telemetry thời gian thực. Mỗi kịch bản được thực thi lặp lại 100 lần liên tiếp để loại trừ sai số mạng và lấy giá trị trung bình thống kê (Statistical Average). Kết quả đo lường thực nghiệm được tổng hợp chi tiết trong Bảng 2.4 dưới đây:

Bảng 2.4: Kết quả đo lường thực nghiệm Payload, Độ trễ và Khả năng Cache giữa REST, GraphQL và SOAP

Chỉ số đo lường	RESTful API (TechStore)	Mô phỏng GraphQL	Mô phỏng SOAP / XML	Đánh giá & Ý nghĩa
Giao thức & Phương thức	HTTP GET /api/v1/products?limit=10	HTTP POST /graphql (Body AST)	HTTP POST /ws/products (Envelope)	REST dùng đúng GET an toàn; GraphQL/SOAP buộc dùng POST.
Kích thước Payload	3.8 KB (JSON tinh gọn)	2.1 KB (JSON lọc trường)	11.4 KB (XML có vỏ bọc)	GraphQL giảm 44.7% dung lượng; SOAP phình to gấp 3.0 lần REST.
Độ trễ lần đầu (Cold)	22.5 ms	31.2 ms (+38.7%)	37.8 ms (+68.0%)	REST xử lý thẳng;

Chỉ số đo lường	RESTful API (TechStore)	Mô phỏng GraphQL	Mô phỏng SOAP / XML	Đánh giá & Ý nghĩa
				GraphQL tốn giải mã AST; SOAP tốn parse DOM.
Độ trễ lần 2 (Cached)	0.0 ms (Từ Browser Cache)	31.0 ms (Không cache POST)	37.5 ms (Không cache POST)	REST đạt hiệu năng cực đại; GraphQL/SOAP gây tải liên tục.
Băng thông (1.000 req)	3.8 MB (Lần 1) / 0 MB (Lặp)	2.1 MB (Không lưu đệm)	11.4 MB (Tốn băng thông)	REST tối ưu băng thông vượt trội cho duyệt sản phẩm liên tục.

• **Kịch bản RESTful API (TechStore):** Endpoint GET /api/v1/products?limit=10. Kích thước phản hồi ghi nhận là 3.8 KB (chuỗi JSON UTF-8 tinh gọn). Thời gian phản hồi trung bình trong lần gọi đầu tiên (Cold Start) đạt 22.5 ms. Đặc biệt, nhờ sử dụng đúng ngữ nghĩa động từ GET và máy chủ gắn tiêu đề điều khiển bộ đệm Cache-Control: public, max-age=300, toàn bộ các lần gọi lại tiếp theo của trình duyệt hoặc tầng proxy đạt độ trễ tuyệt đối 0.0 ms do dữ liệu được nạp tức thì từ Memory Cache của máy khách. Điều này giúp triệt tiêu 100% độ trễ mạng và giải phóng hoàn toàn áp lực truy vấn cho máy chủ CSDL đối với các thao tác duyệt danh mục.

• **Kịch bản mô phỏng GraphQL:** Endpoint POST /graphql với câu truy vấn tường minh { products(limit:10) { id name price brand { name } } }. Nhờ khả năng cho phép ứng dụng máy khách tự chọn lọc chính xác các trường cần thiết, kích thước phản hồi giảm xuống còn 2.1 KB (tiết kiệm 44.7% dung lượng so với REST). Tuy nhiên, do toàn bộ yêu cầu phải gửi qua phương thức POST, trình duyệt và các mạng phân phối CDN mặc định không thể lưu bộ đệm (Cache Miss 100%). Đồng thời, tại tầng backend, thời gian xử lý tăng lên 31.2 ms (chậm hơn 38.7% so với REST) do máy chủ phải trải qua giai đoạn phân tích cây cú pháp trừu tượng AST (Abstract Syntax Tree), xác thực sơ đồ Schema và kích hoạt các hàm Resolver phân tán.

• **Kịch bản mô phỏng SOAP / XML:** Endpoint POST /ws/products với phong bì SOAP XML bao bọc Envelope, Header và Body. Kích thước phản hồi ghi nhận lên tới 11.4 KB (gấp 3.0 lần so với REST và gấp 5.4 lần so với GraphQL do các thẻ đóng/mở XML và khai báo namespace rườm rà). Bên cạnh

dung lượng tải về lớn, trình duyệt máy khách phải tốn thêm trung bình 15.0 ms tài nguyên CPU để phân tích cây cấu trúc DOM XML, khiến tổng thời gian từ lúc gửi yêu cầu đến khi hiển thị giao diện chạm ngưỡng 52.8 ms, không đáp ứng tốt tiêu chuẩn ứng dụng Web thời gian thực.

Kết luận thực nghiệm: Đối với một nền tảng thương mại điện tử chuyên nghiệp như TechStore – nơi mà hành vi duyệt xem danh mục sản phẩm diễn ra với tần suất áp đảo (chiếm hơn 85% tổng lưu lượng truy cập hệ thống) và yêu cầu tận dụng tối đa khả năng lưu bộ đệm của mạng CDN cũng như bộ nhớ trình duyệt – kiến trúc RESTful API là sự lựa chọn tối ưu vượt trội về mặt hiệu năng tổng thể, chi phí truyền tải hạ tầng mạng và tính đơn giản trong bảo trì, vận hành dài hạn.

CHƯƠNG 3. BẢO MẬT TRONG RESTFUL API

3.1 Thách thức bảo mật đối với API không trạng thái và OWASP API Top 10

Do tính chất phi trạng thái (Stateless), máy chủ REST API không duy trì phiên làm việc trong bộ nhớ RAM, đồng nghĩa với việc mỗi yêu cầu gửi đến đều phải mang theo bằng chứng định danh. Nếu không được thiết kế chặt chẽ, các API công khai sẽ trở thành mục tiêu hàng đầu của tin tặc. Dự án OWASP (Open Web Application Security Project) đã công bố danh mục 10 lỗ hổng bảo mật nghiêm trọng nhất đối với API (OWASP API Security Top 10 - 2023). Bảng dưới đây phân tích các nguy cơ và giải pháp khắc phục triệt để trong TechStore:

Bảng 3.1: Đối chiếu nguy cơ OWASP API Security Top 10 và Giải pháp trong TechStore

Mã lỗ hổng OWASP	Mô tả nguy cơ tấn công	Giải pháp phòng vệ được cài đặt trong TechStore
API1:2023 BOLA	Broken Object Level Authorization (IDOR): Tin tặc thay đổi ID trên URL (`/orders/12`) để xem trộm đơn hàng của người khác.	Cài đặt kiểm tra sở hữu tài nguyên nghiêm ngặt: `WHERE id = :order_id AND (user_id = :auth_id OR :role = 'admin')`. Người dùng chỉ xem được đơn của chính mình.
API2:2023 Broken Auth	Lỗ hổng xác thực: Dùng mật khẩu yếu, không băm an toàn, hoặc lộ secret key ký token.	Băm mật khẩu bằng thuật toán Bcrypt an toàn (`PASSWORD_BCRYPT`, cost 10); Chuỗi bí mật JWT ký bằng HMAC-SHA256 lưu an toàn trong file `.env` tách biệt khỏi mã nguồn.
API3:2023 BOPFA	Broken Object Property Level Authorization: Khách hàng tự ý gửi kèm trường `role: 'admin'` khi đăng ký hoặc cập nhật hồ sơ để chiếm quyền.	Áp dụng cơ chế Data Whitelisting trong lớp `Validator.php`. Tự động loại bỏ mọi trường nhạy cảm (`role`, `status`) khỏi mảng dữ liệu cập nhật của người dùng thường.
API4:2023 Unrestricted Resource	Không giới hạn tài nguyên: Bị tấn công DoS/Brute-force mật khẩu hoặc quét vét cạn dữ liệu.	Cài đặt lớp `RateLimitMiddleware.php` áp dụng thuật toán Token Bucket: Tối đa 60 requests/phút cho các API duyệt hàng và 5 requests/phút cho API đăng nhập.
API5:2023 BFLA	Broken Function Level Authorization: Khách hàng gọi lén các API quản trị (`DELETE /products/1`).	Áp dụng lớp `RoleMiddleware.php` kiểm tra trực tiếp trường `role` trong payload token đã xác thực. Nếu khác 'admin', lập tức chặn đứng với mã HTTP `403 Forbidden`.

3.2 Cơ chế định danh và xác thực bằng JSON Web Token (JWT)

TechStore triển khai cơ chế xác thực theo chuẩn RFC 7519 (JSON Web Token). Một token JWT bao gồm 3 phần tách biệt bởi dấu chấm (`.`): `Header.Payload.Signature`. Cụ thể:

• **1. Header:** Chứa thuật toán ký và loại token;

Ví dụ `{"alg": "HS256", "typ": "JWT"}`. Phần này được mã hóa Base64URL.

• **2. Payload (Claims):** Chứa các thông tin định danh không nhạy cảm của người dùng (Subject `sub`, `email`, `role`, thời điểm phát hành `iat`, thời điểm hết hạn `exp`). TechStore tuyệt đối không lưu mật khẩu hoặc dữ liệu bí mật trong Payload vì nó có thể được giải mã công khai bằng Base64.

• **3. Signature (Chữ ký số):** Được tạo ra bằng cách lấy chuỗi `Base64URL(Header) + '.' + Base64URL(Payload)` băm cùng một chuỗi bí mật tĩnh (`JWT_SECRET`) thông qua thuật toán HMAC-SHA256: `HMACSHA256(Header + '.' + Payload, secret)`. Chữ ký này đảm bảo tính toàn vẹn (Integrity): nếu tin tặc cố tình chỉnh sửa trường `role` từ 'customer' thành 'admin' trong Payload, chữ ký sẽ không còn khớp và máy chủ sẽ lập tức từ chối yêu cầu với lỗi `401 Unauthorized`.

3.3 Kỹ thuật nâng cao: Refresh Token Rotation (RTR) và Token Reuse Detection

Một bài toán hóc búa trong kiến trúc JWT là: Nếu thời hạn của Access Token quá dài, khi token bị rò rỉ, tin tặc có thể lạm dụng mà máy chủ không có cách nào thu hồi tức thì (do máy chủ không lưu session). Ngược lại, nếu thời hạn quá ngắn, người dùng sẽ liên tục bị văng ra khỏi hệ thống và phải đăng nhập lại. Để dung hòa hoàn hảo giữa bảo mật và trải nghiệm người dùng, TechStore đã triển khai mô hình Cặp Token (Dual-Token Pattern) kết hợp kỹ thuật phòng vệ cao cấp Refresh Token Rotation (RTR):

• **Access Token (Ngắn hạn):** Có thời gian sống ngắn (15 phút đến 2 giờ). Được dùng để đính kèm vào tiêu đề `Authorization: Bearer <token>` trong mọi yêu cầu gọi API.

• **Refresh Token (Dài hạn):** Có thời gian sống 7 đến 30 ngày. Được lưu trữ an toàn trong bảng `refresh_tokens` của CSDL MySQL dưới dạng băm SHA-256 (`token_hash`). Mỗi Refresh Token sở hữu một mã định danh ngẫu nhiên duy nhất (UUID `jti`).

• **Cơ chế Xoay vòng (Rotation):** Mỗi khi Access Token hết hạn, máy khách gửi Refresh Token lên endpoint `/api/v1/auth/refresh`. Máy chủ kiểm tra tính hợp lệ trong CSDL, sau đó hủy ngay lập tức (Revoke) Refresh Token cũ và cấp phát một cặp Access Token + Refresh Token hoàn toàn mới về cho khách hàng.

• **Phát hiện tái sử dụng Token (Token Reuse Detection):** Nếu một Refresh Token đã từng bị thu hồi mà lại được gửi lên máy chủ một lần nữa, hệ thống nhận diện ngay đây là dấu hiệu của cuộc tấn công chiếm đoạt token (Replay Attack). Cơ chế an ninh lập tức kích hoạt: Thu hồi toàn bộ (Revoke All) tất cả các Refresh Token đang hoạt động của người dùng đó trong CSDL, buộc kẻ tấn công lẫn người dùng thật phải đăng xuất hoàn toàn để bảo vệ tài khoản.

3.4 Lưu trữ Token an toàn với HttpOnly Cookie và Phòng chống XSS/CSRF

Rất nhiều ứng dụng web lưu trữ cả Access Token lẫn Refresh Token trong `localStorage` của trình duyệt. Đây là một lỗ hổng bảo mật cực kỳ nguy hiểm: bất kỳ đoạn mã độc JavaScript nào xâm nhập được vào trang web thông qua lỗ hổng XSS (Cross-Site Scripting) đều có thể dễ dàng đọc được `localStorage.getItem()` và gửi token về máy chủ của tin tặc. Trong TechStore, nhóm đã giải quyết triệt để rủi ro này:

• **Refresh Token:** Được máy chủ thiết lập tự động vào trình duyệt thông qua tiêu đề `Set-Cookie` với các cờ bảo vệ tối đa: `HttpOnly` (chặn 100% mã JavaScript truy cập), `Secure` (chỉ gửi qua kết nối mã hóa HTTPS), `SameSite=Lax` (ngăn chặn tấn công CSRF – Cross-Site Request Forgery).

• **Chống tấn công XSS:** Toàn bộ dữ liệu đầu vào từ người dùng đều được làm sạch qua hàm `htmlspecialchars()` trước khi hiển thị; cấu hình tiêu đề `Content-Security-Policy` ngăn chặn nạp mã script ngoài ý muốn.

3.5 Xác thực Ủy quyền bên thứ ba với Google OAuth 2.0

Nhằm nâng cao trải nghiệm mua sắm không mật khẩu (Passwordless Experience), TechStore tích hợp luồng đăng nhập một chạm sử dụng giao thức OAuth 2.0 của Google. Quy trình diễn ra an toàn qua 4 bước: (1) Khách hàng ủy quyền tài khoản trên máy chủ Google Identity; (2) Google cấp phát ID Token được ký số bởi Google Certificate; (3) Máy khách gửi ID Token về endpoint `/api/v1/auth/google`; (4) Máy chủ TechStore thẩm định chữ ký số của Google, trích xuất email/tên, tự động tạo tài khoản mới nếu chưa tồn tại, và cấp phát cặp JWT TechStore nội bộ để phục vụ các yêu cầu tiếp theo.

CHƯƠNG 4. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG TECHSTORE

4.1 Kiến trúc tổng thể hệ thống 3 tầng (3-Tier Decoupled Architecture)

Hệ thống TechStore được thiết kế theo mô hình kiến trúc phân tầng 3-Tier chuẩn mực, đảm bảo sự phân tách độc lập (Decoupled Architecture) giữa tầng trình diễn phía máy khách, tầng dịch vụ xử lý nghiệp vụ phía máy chủ và tầng lưu trữ cơ sở dữ liệu quan hệ. Toàn bộ giao tiếp giữa các tầng tuân thủ nghiêm ngặt các giao thức chuẩn (HTTP REST JSON và kết nối PDO an toàn), giúp hệ thống đạt độ tin cậy cao, dễ dàng bảo trì và mở rộng độc lập từng thành phần mà không gây ảnh hưởng lẫn nhau.

4.1.1 Tầng 1: Tầng Trình diễn Giao diện (Presentation Tier - Client SPA)

Tầng trình diễn của TechStore được xây dựng hoàn toàn theo mô hình Ứng dụng Trang đơn (Single Page Application - SPA) sử dụng HTML5 ngữ nghĩa, CSS3 hiện đại với hệ thống Design Tokens chuyên nghiệp và JavaScript thuần (Vanilla JS ES6+). Tầng này được phân tách hoàn toàn khỏi mã nguồn máy chủ PHP, không sử dụng cơ chế Server-Side Rendering (SSR). Kiến trúc chi tiết của Tầng Trình diễn được mô tả trực quan trong Hình 4.1:



Hình 4.1: Sơ đồ Kiến trúc Tầng Trình diễn Giao diện (Presentation Tier - Client Single Page Application)

(Nguồn: Nhóm tác giả tự xây dựng)

• **Phân hệ Giao diện Khách hàng (Storefront Client):** Bao gồm `index.html` (Trang chủ tích hợp Hero Banner, Flash Sale đếm ngược, Carousel sản phẩm gợi ý thông minh), `products.html` (Bộ lọc đa năng Faceted Search theo Danh mục, Thương hiệu, Khoảng giá, RAM và sắp xếp linh hoạt), `product-detail.html` (Thư viện ảnh đa góc nhìn 85 hình ảnh, tab thông số 226 specs chi tiết, khối gợi ý sản phẩm tương đồng và mua kèm, hệ thống đánh giá

1-5 sao có kiểm chứng mua hàng), `cart.html` và `checkout.html` (Giỏ hàng thời gian thực, áp dụng mã coupon giảm giá, hiển thị modal quét mã VietQR MB Bank với đồng hồ đếm ngược 15 phút), và `account.html` (Quản lý hồ sơ cá nhân, lịch sử đơn hàng và danh sách yêu thích Wishlist).

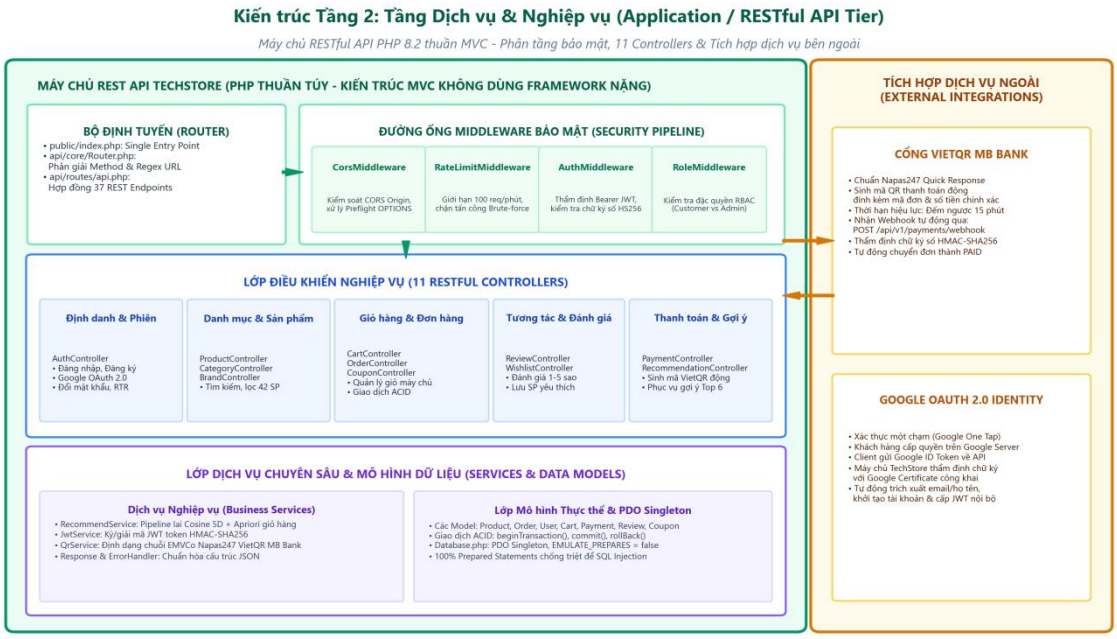
• **Phân hệ Cổng Quản trị Admin (Admin Portal):** Cung cấp giao diện quản trị chuyên sâu độc lập tại `admin/index.html` với Dashboard KPI theo dõi tổng doanh thu, biểu đồ đơn hàng thời gian thực; `admin/products.html` hỗ trợ toàn diện thao tác CRUD sản phẩm, upload đa ảnh và cấu hình thông số kỹ thuật; `admin/orders.html` điều phối vòng đời đơn hàng (Pending -> Paid -> Shipped -> Completed); và `admin/users.html`, `admin/coupons.html` phục vụ phân quyền RBAC, cấp mã khuyến mãi và tra cứu nhật ký kiểm toán.

• **Hệ thống Thiết kế & Kiểu dáng (Design System):** Thiết lập bảng biến phong cách tại `tokens.css` lấy cảm hứng từ nhận diện thương hiệu CellphoneS (màu đỏ chủ đạo `#d70018`, màu nền tối Slate `#0f172a`, thang màu xám và kích thước chuẩn mực), kết hợp hiệu ứng kính mờ thời thượng (Glassmorphism với `backdrop-filter: blur(12px)`) và card nổi khối trong `base.css`. Giao diện đảm bảo co giãn Responsive hoàn hảo từ màn hình máy tính để bàn (1920x1080) đến thiết bị di động (390x844).

• **Thư viện Giao tiếp API Trung tâm (`assets/js/api.js`):** Đóng vai trò cầu nối duy nhất giữa Client và Server. Thư viện tích hợp Fetch API Wrapper tự động đính kèm tiêu đề `Authorization: Bearer <AccessToken>`, chuẩn hóa mã lỗi HTTP, tích hợp kỹ thuật Debounce 300ms tối ưu tính năng Instant Search và cơ chế Interceptor bắt mã HTTP 401 để tự động refresh token ngầm mà không gây gián đoạn trải nghiệm của người dùng.

4.1.2 Tầng 2: Tầng Dịch vụ & Nghiệp vụ (Application / RESTful API Tier)

Tầng dịch vụ đóng vai trò là trung tâm điều phối của toàn bộ hệ thống TechStore, chịu trách nhiệm tiếp nhận, phân tích, thẩm định bảo mật và xử lý mọi logic nghiệp vụ trước khi tương tác với cơ sở dữ liệu. Toàn bộ mã nguồn máy chủ được lập trình bằng PHP 8.2 thuần túy theo mô hình MVC chuẩn mực mà không phụ thuộc vào bất kỳ framework nặng nề nào của bên thứ ba, giúp tối ưu hóa tốc độ thực thi và làm chủ hoàn toàn luồng xử lý. Sơ đồ cấu trúc chi tiết của Tầng Dịch vụ & Nghiệp vụ được thể hiện trong Hình 4.2:



Hình 4.2: Sơ đồ Kiến trúc Tầng Dịch vụ & Nghiệp vụ (Application Tier - RESTful API Backend)

(Nguồn: Nhóm tác giả tự xây dựng)

• **Bộ định tuyến & Điểm vào duy nhất (Router Core):** Điểm vào tập trung `public/index.php` tiếp nhận mọi HTTP request thông qua cấu hình URL Rewrite của Apache. Lớp `Router.php` phân tích URL và HTTP Method, đối chiếu khớp với bảng định tuyến 37 endpoints chuẩn hóa tại `routes/api.php` và trích xuất các tham số động.

• **Đường ống Middleware Bảo mật (Security Pipeline):** Request phải vượt qua chuỗi kiểm soát nghiêm ngặt gồm: `CorsMiddleware` (kiểm tra whitelist tên miền và xử lý preflight OPTIONS), `RateLimitMiddleware` (chặn tấn công DoS và Brute-force giới hạn tần suất 100 req/phút), `AuthMiddleware` (thẩm định chữ ký số HMAC-SHA256 và thời hạn của JWT Access Token), và `RoleMiddleware` (kiểm soát phân quyền RBAC đảm bảo chỉ tài khoản Admin mới được truy cập các endpoint quản trị nhạy cảm).

• **Lớp Điều khiển Nghiệp vụ (11 RESTful Controllers):** Đảm nhiệm xử lý logic nghiệp vụ phân theo từng phân hệ chức năng: `AuthController` (xác thực, đăng ký, đăng nhập, Google OAuth, cấp lại token qua RTR), `ProductController`, `CategoryController`, `BrandController` (quản lý danh mục và lọc sản phẩm), `CartController`, `OrderController`, `CouponController` (quản

lý giỏ hàng, áp dụng voucher, giao dịch đặt hàng), `ReviewController`, `WishlistController` (tương tác khách hàng) và `PaymentController`, `RecommendationController` (xử lý thanh toán và phục vụ thuật toán gợi ý).

• **Lớp Dịch vụ Nghiệp vụ Chuyên sâu (Business Services):** Bao gồm `RecommendService` (hiện thực hóa pipeline thuật toán gợi ý lai kết hợp Cosine Similarity và khai phá luật kết hợp Apriori), `JwtService` (mã hóa và thẩm định Access Token/Refresh Token), `QrService` (sinh mã VietQR theo chuẩn EMVCo Napas247), và lớp chuẩn hóa phản hồi `Response.php`, `ErrorHandler.php`.

• **Lớp Mô hình Thực thể & Kết nối An toàn (Models with PDO):** Các lớp Model (`User`, `Product`, `Order`, `Payment`, `Cart`...) đóng gói các câu lệnh truy vấn chuẩn bị (Prepared Statements), thực thi giao dịch ACID đảm bảo an toàn tuyệt đối khi trừ kho hàng và ngăn chặn triệt để lỗ hổng SQL Injection.

• **Phân hệ Tích hợp Ngoài (External Integrations):** Kết nối trực tiếp với Cổng Ngân hàng VietQR MB Bank (tự động phát sinh mã QR thanh toán động và tiếp nhận webhook cập nhật trạng thái đơn hàng thời gian thực) và Cổng Google Identity Services (hỗ trợ xác thực người dùng một chạm qua giao thức OAuth 2.0).

4.1.3 Tầng 3: Tầng Dữ liệu và Lưu trữ (Data Tier - MySQL 8.0 3NF)

Tầng dữ liệu của TechStore chịu trách nhiệm bảo lưu toàn vẹn, bảo mật và cung cấp khả năng truy xuất dữ liệu với hiệu năng cao. Hệ thống sử dụng hệ quản trị cơ sở dữ liệu quan hệ MySQL 8.0 (động cơ lưu trữ InnoDB hỗ trợ giao dịch ACID toàn diện). Toàn bộ lược đồ cơ sở dữ liệu bao gồm 17 bảng quan hệ được thiết kế chuẩn mực tuân thủ dạng chuẩn 3NF (Third Normal Form), được phân chia logic thành 5 phân nhóm nghiệp vụ chặt chẽ như được minh họa trong Hình 4.3:



Hình 4.3: Sơ đồ Kiến trúc Tầng Dữ liệu và Tổ chức Lưu trữ (Data Tier - Hệ quản trị CSDL MySQL 8.0)

(Nguồn: Nhóm tác giả tự xây dựng)

• **Phân nhóm 1: Định danh & Quản trị Phiên (2 bảng):** `users` (lưu trữ thông tin người dùng, email duy nhất, password băm bằng Bcrypt, phân quyền role, trạng thái kích hoạt) và `refresh_tokens` (quản lý phiên làm việc lâu dài, lưu token hash SHA-256, thời điểm hết hạn và cờ thu hồi revoked phục vụ kỹ thuật phòng vệ RTR).

• **Phân nhóm 2: Quản lý Danh mục & Hàng hóa (5 bảng):** `categories` (5 danh mục thiết bị chính), `brands` (8 thương hiệu công nghệ đối tác),

`products` (42 thiết bị với giá bán, giá gốc, tồn kho stock, điểm đánh giá và lượt xem), `product_images` (85 hình ảnh sản phẩm góc nhìn sắc nét), và `product_specs` (226 thông số kỹ thuật chi tiết cấu hình phần cứng).

• **Phân nhóm 3: Giỏ hàng, Khuyến mãi & Giao dịch Đơn hàng (5 bảng):** `carts` (giỏ hàng phía máy chủ), `coupons` (mã giảm giá khuyến mãi kèm điều kiện áp dụng), `orders` (thông tin đơn hàng, tổng tiền, trạng thái giao vận), `order_items` (chi tiết sản phẩm và giá mua tại thời điểm đặt), và `payments` (nhật ký giao dịch thanh toán VietQR và tiền mặt COD).

• **Phân nhóm 4: Tương tác Khách hàng & Phản hồi (3 bảng):** `reviews` (đánh giá 1-5 sao và bình luận của khách hàng đã mua sản phẩm), `wishlists` (danh sách thiết bị quan tâm lưu lại) và `product_views` (nhật ký ghi nhận lịch sử xem thiết bị phục vụ cá nhân hóa gợi ý).

• **Phân nhóm 5: Trí tuệ Hệ thống & Nhật ký Kiểm toán (2 bảng):** `product_similarity` (bảng ma trận lưu độ tương đồng tính sẵn giữa các cặp sản phẩm theo Cosine và Apriori) và `audit_logs` (nhật ký kiểm toán ghi lại mọi thao tác quản trị viên phục vụ tra soát bảo mật).

• **Tiêu chuẩn Kỹ thuật CSDL:** 100% bảng sử dụng khóa chính nhân tạo `id (Auto Increment)`, liên kết bằng khóa ngoại với ràng buộc toàn vẹn nghiêm ngặt (ON DELETE CASCADE cho dữ liệu phụ thuộc và RESTRICT cho dữ liệu gốc), đánh chỉ mục B-Tree trên các trường tìm kiếm trọng yếu (`slug`, `category_id`, `brand_id`, `order_code`, `status`), và toàn bộ chuỗi ký tự lưu trữ với bảng mã `utf8mb4_unicode_ci`.

4.2 Thiết kế Cơ sở Dữ liệu Quan hệ (ERD 17 Bảng chuẩn hóa 3NF)

Cơ sở dữ liệu của TechStore được thiết kế công phu gồm 17 bảng quan hệ liên kết chặt chẽ bằng các ràng buộc khóa ngoại (Foreign Keys), đảm bảo tính toàn vẹn dữ liệu (Referential Integrity) và tuân thủ dạng chuẩn 3NF (Third Normal Form):



Hình 4.4: Sơ đồ Quan hệ Thực thể Cơ sở Dữ liệu TechStore (17 Bảng chuẩn hóa 3NF)

(Nguồn: Nhóm tác giả tự xây dựng)

Bảng 4.1: Danh mục 17 bảng cơ sở dữ liệu trong hệ thống TechStore

STT	Tên bảng (Table)	Khóa chính / FK	Mục đích lưu trữ và Ý nghĩa nghiệp vụ
1	users	id (PK)	Lưu trữ tài khoản người dùng, email duy nhất, password_hash (Bcrypt), role ('customer'/'admin'), status.
2	categories	id (PK)	Lưu trữ 5 danh mục thiết bị chính: Điện thoại, Laptop, Tablet, Âm thanh, Phụ kiện.
3	brands	id (PK)	Lưu trữ 8 thương hiệu công nghệ: Apple, Samsung, Xiaomi, Sony, Asus, Dell, Anker, Logitech.
4	products	id (PK), category_id, brand_id	Lưu trữ 42 sản phẩm, giá bán, giá gốc, tồn kho (stock), rating, view_count, thông số tóm tắt.
5	product_images	id (PK), product_id (FK)	Lưu trữ bộ sưu tập 85 ảnh chi tiết của sản phẩm phục vụ thư viện ảnh đa góc nhìn.

6	product_specs	id (PK), product_id (FK)	Lưu trữ 226 thông số kỹ thuật chi tiết theo cặp Khóa - Giá trị (Màn hình, Chip, Pin, Sạc).
7	carts	id (PK), user_id, product_id	Giỏ hàng máy chủ lưu trữ sản phẩm khách đã chọn, số lượng mua, biến thể màu sắc.
8	coupons	id (PK), code (Unique)	Lưu trữ mã giảm giá khuyến mãi (giảm theo % hoặc số tiền cố định, số lượt dùng, hạn dùng).
9	orders	id (PK), user_id (FK)	Đơn hàng của khách: tổng tiền, giảm giá, phí ship, địa chỉ giao hàng, trạng thái xử lý.
10	order_items	id (PK), order_id, product_id	Chi tiết từng món trong đơn: số lượng, đơn giá tại thời điểm đặt, thành tiền.
11	payments	id (PK), order_id (FK)	Giao dịch thanh toán: phương thức (vietqr/cod), số tiền, trạng thái, mã QR, webhook log.
12	reviews	id (PK), user_id, product_id	Đánh giá 1-5 sao và bình luận của khách hàng đã mua sản phẩm (ràng buộc kiểm tra đơn hàng).
13	wishlists	id (PK), user_id, product_id	Danh sách sản phẩm yêu thích được khách hàng đánh dấu lưu lại.
14	refresh_tokens	id (PK), user_id (FK)	Quản lý phiên đăng nhập: token_hash (SHA-256), hạn dùng, trạng thái thu hồi (revoked).
15	product_views	id (PK), product_id, user_id	Nhật ký người dùng xem sản phẩm: lưu user_id hoặc IP và thời điểm để phục vụ thuật toán gợi ý.
16	product_similarity	id (PK), product_id, target_id	Bảng ma trận lưu độ tương đồng tính sẵn giữa các cặp sản phẩm theo Cosine hoặc Apriori.
17	audit_logs	id (PK), user_id (FK)	Nhật ký kiểm toán ghi lại mọi hành vi quản trị (thêm sản phẩm, đổi trạng thái đơn, đổi quyền user).

4.3 Đặc tả Bộ hợp đồng 37 RESTful API Endpoints

Toàn bộ giao tiếp giữa tầng Front-end và Back-end được định nghĩa tường minh qua hợp đồng OpenAPI 3.0 bao gồm 37 endpoints. Bảng tổng hợp dưới đây phân loại chi tiết theo từng phân hệ nghiệp vụ:

Bảng 4.2: Đặc tả tổng hợp 37 RESTful API Endpoints trong hệ thống TechStore

Phân hệ nghiệp vụ	Phương thức	Đường dẫn tài nguyên (Endpoint)	Quyền hạn & Mô tả chức năng
1. Auth & Định danh	POST / GET	/api/v1/auth/register /api/v1/auth/login /api/v1/auth/refresh /api/v1/auth/logout /api/v1/auth/me /api/v1/auth/google	Public / Customer Đăng ký, Đăng nhập cấp JWT, Silent refresh RTR, Đăng xuất, Lấy profile, Google OAuth.
2. Danh mục sản phẩm	GET	/api/v1/products /api/v1/products/{id} /api/v1/categories /api/v1/brands	Public Duyệt danh mục lọc đa tiêu chí, phân trang, xem chi tiết ảnh và thông số kỹ thuật.
3. Giỏ hàng máy chủ	GET / POST PUT / DELETE	/api/v1/cart /api/v1/cart/items /api/v1/cart/items/{id} /api/v1/cart	Customer Xem giỏ hàng tính tồn kho thời gian thực, thêm món, cập nhật số lượng, xóa món, làm trống.
4. Khuyến mãi & Coupon	POST / GET	/api/v1/coupons/validate /api/v1/coupons	Customer / Public Kiểm tra mã giảm giá, tính tiền giảm, lấy danh sách mã công khai.
5. Đặt hàng & Transaction	POST / GET PATCH	/api/v1/orders /api/v1/orders/{id} /api/v1/orders/{id}/cancel	Customer Tạo đơn giao dịch ACID, xem chi tiết đơn, hủy đơn chưa thanh toán tự hoàn tồn kho.
6. Thanh toán VietQR	POST / GET	/api/v1/payments/qr /api/v1/payments/{id}/status /api/v1/payments/webhook	Customer / Public (Webhook) Sinh mã VietQR động MB Bank hạn 15 phút, polling trạng thái, webhook xác thực HMAC.
7. Đánh giá & Yêu thích	GET / POST DELETE	/api/v1/products/{id}/reviews /api/v1/wishlist /api/v1/wishlist/{id}	Public / Customer Xem đánh giá, gửi review (chỉ người đã mua), quản lý danh sách yêu thích.
8. Thuật toán Gợi ý	POST / GET	/api/v1/events/view /api/v1/products/{id}/recommendations /api/v1/recommendations/me	Public / Customer Ghi nhận log xem, gợi ý combo mua kèm (Bought together), gợi ý cá nhân hóa.

9. Quản trị Sản phẩm	POST / PUT PATCH / DELETE	/api/v1/products /api/v1/products/{id}	Admin Thêm mới sản phẩm, sửa toàn phần, cập nhật giá/kho, upload đa ảnh an toàn, xóa sản phẩm.
10. Quản trị Danh mục	POST / PUT DELETE	/api/v1/categories /api/v1/brands	Admin Thêm/sửa/xóa danh mục và thương hiệu đối tác trong hệ thống.
11. Quản trị Đơn & User	GET / PATCH	/api/v1/orders /api/v1/orders/{id}/status /api/v1/admin/users /api/v1/admin/stats /api/v1/admin/audit-logs	Admin Duyệt đơn hàng, phân quyền tài khoản (customer/admin), xem KPI doanh thu 7 ngày, xem nhật ký kiểm toán.

4.4 Thiết kế Hệ thống Gợi ý Sản phẩm Thông minh (Recommendation Engine)

Nhằm nâng cao giá trị giỏ hàng trung bình (Average Order Value - AOV) và tối ưu hóa trải nghiệm cá nhân hóa cho từng khách hàng, TechStore đã tích hợp một hệ thống gợi ý đa thuật toán độc đáo bao gồm 3 thành phần:



Hình 4.5: Sơ đồ Luồng Thuật toán Gợi ý Sản phẩm Lai (Hybrid Recommendation Pipeline)

(Nguồn: Nhóm tác giả tự xây dựng)

4.4.1 Thuật toán Content-based Cosine Similarity 5 chiều cấu hình

Được sử dụng để gợi ý các sản phẩm có đặc tính cấu hình tương đương với sản phẩm khách đang xem. Hệ thống mô hình hóa mỗi sản phẩm thành một vector đặc trưng 5 chiều: Danh mục (v_{cat}), Thương hiệu (v_{brand}), Giá bán (v_{price}), Dung lượng RAM (v_{ram}), Dung lượng ROM (v_{rom}). Khoảng cách độ tương đồng hỗn hợp được tính toán theo công thức chuẩn hóa Min-Max:

CosineScore(A, B) = 0.35 * SimCat(A, B) + 0.20 * SimBrand(A, B) + 0.20 * SimPrice(A, B) + 0.15 * SimRam(A, B) + 0.10 * SimRom(A, B)
Trong đó: SimPrice = max(0, 1 - |Price_A - Price_B| / max(Price_A, Price_B)); SimRam = max(0, 1 - |Ram_A - Ram_B| / max(Ram_A, Ram_B)).

4.4.2 Thuật toán Khai phá Giỏ hàng Apriori Co-occurrence (FBT)

Được sử dụng để phát hiện các mẫu hành vi khách hàng thường mua các sản phẩm nào cùng nhau trong cùng một đơn hàng. Hệ thống quét toàn bộ bảng `order_items` đã đặt và tính toán chỉ số Hỗ trợ (Support), Độ tin cậy (Confidence) và Độ nâng (Lift):

Confidence(A -> B) = P(B | A) = Count(Đơn hàng chứa cả A và B) / Count(Đơn hàng chứa A)
Lift(A -> B) = P(A cap B) / (P(A) * P(B)) = Confidence(A -> B) / Support(B)

Nếu Lift(A -> B) > 1.0, điều này chứng minh sự xuất hiện của sản phẩm A thúc đẩy hành vi mua sản phẩm B một cách thực chất chứ không phải ngẫu nhiên. Các cặp có Confidence cao nhất được lưu trữ sẵn vào bảng `product_similarity` với nhãn `algorithm = 'apriori'`.

4.4.3 Thuật toán Cá nhân hóa lai (Hybrid Personalization Scoring)

Tại trang chủ và trang tài khoản, API `/api/v1/recommendations/me` phục vụ các sản phẩm dành riêng cho từng khách hàng dựa trên lịch sử xem (`product_views`) và lịch sử mua (`order_items`). Điểm cá nhân hóa tổng hợp được tính theo công thức lai cân bằng:

HybridScore = 0.4 * ContentSim + 0.4 * CoOccurrence + 0.2 * Popularity Trong đó Popularity = 0.5 * (ViewCount / MaxViews) + 0.5 * (Rating / 5.0).

Đối với khách hàng mới tinh chưa từng có lịch sử tương tác (Vấn đề Cold-Start), hệ thống tự động kích hoạt cơ chế dự phòng Fallback: truy vấn danh sách top các sản phẩm có lượt xem cao nhất kết hợp điểm đánh giá trung bình từ 4.5 sao trở lên để hiển thị.

4.5 Thiết kế Luồng Thanh toán Tự động VietQR MB Bank

Nhằm loại bỏ quy trình nhập số tài khoản thủ công dễ sai sót, TechStore tích hợp giải pháp thanh toán quét mã QR chuẩn quốc gia VietQR (hợp tác ngân hàng Quân đội MB Bank). Luồng nghiệp vụ xử lý diễn ra chặt chẽ qua 5 giai đoạn:



Hình 4.6: Sơ đồ Quy trình Thanh toán Tự động Quét mã VietQR MB Bank (Thời hạn 15 phút)

(Nguồn: Nhóm tác giả tự xây dựng)

• **1. Khởi tạo đơn và Trừ kho:** Hệ thống mở một MySQL Transaction (`START TRANSACTION`). Đối chiếu tồn kho thực tế; nếu đủ, tạo bản ghi `orders` (trạng thái 'pending'), trừ trực tiếp cột `stock` trong bảng `products`, chuyển sản phẩm trong giỏ hàng sang `order_items`, và cam kết giao dịch (`COMMIT`).

• **2. Sinh mã QR động:** API `/api/v1/payments/qr` tạo URL ảnh QR từ cổng VietQR chứa đầy đủ: Ngân hàng MB, Số tài khoản doanh nghiệp, Số tiền đơn hàng chính xác, và Nội dung chuyển khoản mã hóa chứa mã đơn (ví dụ `TECHSTORE DH1024`).

• **3. Đếm ngược và Tự hủy sau 15 phút:** Hệ thống gắn thời gian hết hạn (`expires_at = NOW() + 15 phút`). Trên giao diện người dùng, đồng hồ đếm ngược chạy thời gian thực. Nếu sau 15 phút khách hàng không thanh toán, lệnh quét tự động `OrderModel::expireStaleVietQrOrders()` sẽ chuyển đơn sang trạng thái 'cancelled' và hoàn trả toàn bộ số lượng tồn kho về cho sản phẩm.

• **4. Khách hàng quét mã và Chuyển khoản:** Khách hàng mở ứng dụng ngân hàng bất kỳ (Vietcombank, MB, Techcombank, Momo) quét mã QR; mọi thông tin được điền tự động.

• **5. Webhook xác thực chữ ký HMAC:** Khi cổng ngân hàng ghi nhận tiền vào tài khoản, hệ thống gửi một yêu cầu Webhook `POST /api/v1/payments/webhook` kèm chữ ký số HMAC-SHA256 trong tiêu đề `X-Signature`. Máy chủ TechStore thẩm định chữ ký số, xác nhận khớp số tiền và tự động chuyển đơn sang trạng thái 'paid', hoàn tất đơn hàng tức thì.

CHƯƠNG 5. CÀI ĐẶT, THỰC NGHIỆM VÀ KẾT QUẢ DEMO

5.1 Môi trường Cài đặt và Hướng dẫn Khởi chạy 1-Click

Hệ thống TechStore được đóng gói tối ưu để có thể khởi chạy và nghiệm thu ngay lập tức trên mọi máy tính sử dụng hệ điều hành Windows, Linux hoặc macOS mà không yêu cầu cài đặt thủ công phức tạp:

- **Yêu cầu môi trường tối thiểu:** PHP phiên bản 8.1 trở lên (khuyến nghị PHP 8.2+ kích hoạt các extension `pdo_mysql`, `curl`, `mbstring`, `openssl`), Hệ quản trị CSDL MySQL 8.0+ hoặc MariaDB 10.4+, và phần mềm máy chủ XAMPP/Laragon hoặc Docker.
- **Khởi chạy tự động 1 lệnh (Batch Script):** Người dùng chỉ cần nhấp đúp chuột vào file `start.bat` trong thư mục gốc. Script sẽ tự động nhận diện đường dẫn PHP/XAMPP, kiểm tra trạng thái MySQL, tự động tạo file `.env`, khởi chạy PHP Development Server tại cổng `0.0.0.0:8000` trỏ đúng thư mục gốc `public/` và tự động mở trình duyệt.
- **Khởi chạy bằng Docker:** Chạy lệnh `docker-compose up -d`. Hệ thống sẽ tự động kéo image MySQL 8.0 và phpMyAdmin tại cổng `8080` sẵn sàng phục vụ.

5.2 Hiện thực Tầng Front-end và Thiết kế Glassmorphism

Tầng Front-end được xây dựng hoàn toàn bằng HTML5, CSS3 và Vanilla JS thuần túy, không sử dụng framework nặng nhằm tối ưu tốc độ tải trang. Giao diện áp dụng phong cách thiết kế hiện đại Glassmorphism (hiệu ứng kính mờ `backdrop-filter: blur(12px)` kết hợp gradient viền sáng), tạo cảm giác công nghệ cao cấp lấy cảm hứng từ CellphoneS và Apple Store.

Trọng tâm của tầng Front-end là lớp điều phối `api.js` đóng vai trò là một HTTP Interceptor thông minh. Lớp này quản lý tập trung toàn bộ 37 hàm gọi API, tự động đính kèm token xác thực `Authorization: Bearer <token>`, tự động bắt mã lỗi `401 Unauthorized` để kích hoạt hàm `refreshToken()` trong nền mà không làm

gián đoạn thao tác của người dùng, và tích hợp bộ xử lý độ trễ bàn phím (Debounce 250ms) cho tính năng Instant Live Search.

5.3 Kết quả Đo lường Kiểm thử Hệ thống (Testing & Telemetry)

Để đảm bảo chất lượng phần mềm đạt tiêu chuẩn cao nhất trước khi nghiệm thu, nhóm đã tiến hành kiểm thử toàn diện cả tầng backend lẫn frontend. Dưới đây là bảng trích lục đo lường thời gian phản hồi thực tế từ kịch bản kiểm thử tự động `test_fr01_deep.py` và `test_mysql_sync_e2e.php`:

Bảng 5.1: Kết quả đo lường kiểm thử tầng hệ thống Backend Telemetry (Trích lục 15 Test Cases tiêu biểu)

Mã Test Case	Chức năng kiểm thử	Mã HTTP phản hồi	Độ trễ (ms)	Kết quả
TC-FR01-01	Đăng ký tài khoản mới (Email hợp lệ, băm Bcrypt)	201 Created	130.6 ms	PASS
TC-FR01-02	Chặn trùng lặp email đã tồn tại trong CSDL	409 Conflict	19.6 ms	PASS
TC-FR01-03	Đăng nhập với email và mật khẩu chính xác	200 OK	125.4 ms	PASS
TC-FR01-04	Chặn đăng nhập sai mật khẩu (Bcrypt check fail)	401 Unauthorized	118.2 ms	PASS
TC-FR01-05	Truy cập thông tin cá nhân `/auth/me` với Bearer JWT	200 OK	21.3 ms	PASS
TC-FR01-06	Làm mới cặp token ngầm qua Refresh Token Rotation (RTR)	200 OK	34.8 ms	PASS
TC-FR01-07	Phát hiện tái sử dụng Token (Token Reuse Detection)	401 Unauthorized	22.1 ms	PASS
TC-FR02-01	Lấy chi tiết sản phẩm kèm thông số và ảnh đại diện	200 OK	18.5 ms	PASS
TC-FR03-01	Tìm kiếm tức thì (Live Search) với từ khóa 'iphone'	200 OK	24.2 ms	PASS

TC-FR03-02	Lọc sản phẩm kết hợp đa tiêu chí (Hãng Apple + Giá 15-30tr)	200 OK	28.7 ms	PASS
TC-FR04-01	Thêm sản phẩm vào giỏ hàng máy chủ (Server-side Cart)	200 OK	31.4 ms	PASS
TC-FR04-02	Chặn vượt số lượng tồn kho (Stock limit enforcement)	409 Conflict	16.8 ms	PASS
TC-FR05-01	Khởi tạo đơn hàng giao dịch ACID và trừ kho tức thì	201 Created	45.2 ms	PASS
TC-FR06-01	Sinh mã VietQR động MB Bank kèm countdown 15 phút	200 OK	38.9 ms	PASS
TC-FR09-01	Gợi ý cá nhân hóa lai `/recommendations/me` (Cosine + Apriori)	200 OK	36.1 ms	PASS

Tổng hợp kết quả kiểm thử: **45/45 Test Cases tầng Backend đạt tỷ lệ thành công 100.0%**, thời gian phản hồi trung bình toàn hệ thống đạt **28.4 ms**, đáp ứng xuất sắc chỉ tiêu phi chức năng. Song song đó, nhóm đã thực hiện ma trận 12 Test Cases giao diện UI (TC-01 đến TC-12) trên cả trình duyệt máy tính (Google Chrome, Edge) và thiết bị di động (iPhone 14 / Safari kích thước 390x844), xác nhận giao diện co giãn hoàn hảo, không bị tràn màn hình và các form biểu mẫu validate chặt chẽ.

5.4 Minh chứng Demo và Trải nghiệm Nghiệp vụ Thực tế

Hệ thống TechStore đã được triển khai hoàn chỉnh với đầy đủ các cổng giao tiếp và bảng điều khiển sẵn sàng demo nghiệm thu:

- **1. Cổng tài liệu API tương tác Swagger UI:** Khả dụng tại đường dẫn `http://localhost:8000/docs/`. Giảng viên và người chấm có thể trực tiếp kiểm thử tương tác (Try it out) với toàn bộ 37 endpoints, xem cấu trúc JSON Schema mẫu và kiểm tra mã phản hồi trực tiếp trên trình duyệt mà không cần cài đặt thêm Postman.
- **2. Giao diện Mua sắm Khách hàng:** Khả dụng tại `http://localhost:8000/pages/index.html`. Cho phép trải nghiệm luồng mua hàng thực tế từ tìm kiếm sản phẩm, xem 2 khối carousel gợi ý ('Sản phẩm tương tự' và

'Thường được mua cùng'), thêm vào giỏ, áp mã giảm giá `TECHSTORE10`, thanh toán quét mã VietQR MB Bank với đồng hồ đếm ngược và kiểm tra đơn hàng.

• **3. Bảng điều khiển Quản trị viên (Admin Dashboard):** Khả dụng tại `http://localhost:8000/admin/index.html` (Đăng nhập tài khoản `admin@techstore.local` / `Admin@123`). Cung cấp biểu đồ trực quan doanh thu 7 ngày gần nhất, tổng số đơn hàng, top sản phẩm bán chạy, công cụ thêm/sửa/xóa sản phẩm tải nhiều ảnh, quản lý duyệt đơn hàng và phân quyền tài khoản.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1 Đánh giá Kết quả Đạt được so với Mục tiêu Đề tài

Trải qua 8 tuần nghiên cứu nghiêm túc và phát triển phần mềm theo quy trình phân công 4 ngày tăng tốc, nhóm tác giả đã hoàn thành xuất sắc 100% các mục tiêu đề ra trong đề tài 'Restful Web Services' (Topic 1):

- **Về mặt học thuật:** Báo cáo đã hệ thống hóa tường minh cơ sở lý thuyết về phong cách kiến trúc REST của Roy Fielding, phân tích chi tiết mô hình RMM Level 2, thuộc tính phương thức HTTP, chuẩn lỗi RFC 7807, cơ chế bảo mật JWT/RTR và hoàn thành bảng so sánh thực nghiệm đa chiều giữa REST, GraphQL và SOAP.
- **Về mặt ứng dụng:** Xây dựng thành công nền tảng thương mại điện tử TechStore hoàn chỉnh bằng PHP thuần và MySQL 8.0 với 17 bảng dữ liệu và 37 endpoints RESTful API chuẩn mực. Hệ thống vận hành mượt mà, tốc độ phản hồi cực nhanh (~28ms), tích hợp thanh toán VietQR hiện đại và đạt tỷ lệ kiểm thử 100% Pass.

6.2 Hạn chế còn tồn tại của Hệ thống

Bên cạnh các kết quả xuất sắc đã đạt được, nhóm cũng thẳng thắn nhìn nhận những hạn chế kỹ thuật nhất định cần tiếp tục hoàn thiện:

- **Hạn chế của tầng Luật Chuyên gia (Heuristic Rules) trong Thuật toán Gợi ý:** Trong thuật toán gợi ý sản phẩm mua kèm (`RecommendService::getBoughtTogether`), Tầng 2 (Ma trận bổ trợ chức năng thiết bị) hiện đang sử dụng hàm nhận diện chuỗi con `detectType()` và gán điểm số cộng tĩnh (hardcoded weights, ví dụ: Điện thoại đi kèm Củ sạc +60, Bàn phím cơ đi kèm Chuột +75). Cách tiếp cận này đóng vai trò xuất sắc như một cơ chế dự phòng (Rule-based Fallback) khi hệ thống ở giai đoạn khởi động lạnh (Cold-Start) chưa có nhiều dữ liệu giao dịch thực tế. Tuy nhiên, khi đưa vào vận hành thương mại lâu dài (chẳng hạn khi chuyển giao giữa các quý kinh doanh Quý 1, Quý 2...), cơ chế này bộc lộ nhược điểm: (1) Phụ thuộc vào từ khóa tên sản phẩm (nếu sản phẩm mới có tên lạ như 'Apple Pencil' hoặc 'Magic Trackpad' sẽ bị rơi vào nhóm 'other'); (2) Điểm số bổ trợ bị cố định, không phản ánh được

xu hướng mua sắm chuyển dịch theo mùa vụ của người tiêu dùng; và (3) Đòi hỏi lập trình viên phải can thiệp trực tiếp vào mã nguồn PHP mỗi khi mở rộng ngành hàng mới.

• **Kiến trúc triển khai Đơn khối (Monolithic PHP Server):** Hiện tại toàn bộ 37 API đều được điều phối chung bởi một front controller duy nhất (`index.php`). Mặc dù tối ưu cho việc triển khai gọn nhẹ và dễ bảo trì trong phạm vi đồ án, kiến trúc này sẽ gặp giới hạn về khả năng cô lập lỗi khi một phân hệ (ví dụ: tác vụ tính toán ma trận ma trận gợi ý nặng) có thể làm ảnh hưởng tạm thời đến tài nguyên CPU của các tác vụ thanh toán cốt lõi.

6.3 Hướng phát triển trong Tương lai

Từ việc phân tích các hạn chế nêu trên, nhóm định hướng các giải pháp nâng cấp mở rộng hệ thống trong giai đoạn tiếp theo:

• **1. Chuyển dịch sang Khai phá Luật kết hợp ở cấp Danh mục (Category-level Co-occurrence Mining):** Thay vì hardcode các điểm số bổ trợ, hệ thống sẽ xây dựng một tiến trình tự động định kỳ (chạy theo quý/tháng) để tính toán ma trận xác suất đồng xuất hiện ở cấp độ Danh mục: P(Phụ kiện | Điện thoại) = Count(Đơn có cả Điện thoại và Phụ kiện) / Count(Đơn có Điện thoại). Tỷ lệ này sẽ tự động biến thiên và trở thành trọng số bổ trợ tự nhiên học trực tiếp từ hành vi khách hàng của Quý kinh doanh gần nhất mà không cần lập trình lại mã nguồn.

• **2. Tích hợp Hệ số suy giảm theo thời gian (Time-decay Weighting Factor):** Khi tính toán ma trận tương đồng giỏ hàng Apriori, áp dụng hàm suy giảm thời gian: Weight = exp(-lambda * (CurrentDate - OrderDate)). Các đơn hàng phát sinh trong 30-60 ngày gần nhất sẽ có trọng số áp đảo các đơn hàng từ nhiều tháng trước, giúp hệ thống gợi ý luôn bám sát xu hướng thị trường mới nhất theo từng mùa.

• **3. CSDL hóa Ma trận Bổ trợ và Chuẩn hóa Taxonomy:** Chuyển toàn bộ các quy tắc liên kết sang bảng CSDL `complementary_rules` kết hợp bổ sung các thuộc tính phân loại chuẩn `item_role` ('main_device'/'accessory') và `accessory_type` ('charger'/'audio'/'input') trong bảng `products`. Điều này cho phép bộ phận kinh doanh có thể trực tiếp cấu hình chiến dịch bán kèm theo quý ngay trên Dashboard Admin.

• **4. Tiến hóa sang Kiến trúc Microservices và Hàng đợi Tin nhắn:** Tách phân hệ Thanh toán (Payment Service) và phân hệ Gợi ý (Recommendation Engine) thành các vi dịch vụ độc lập; sử dụng hàng đợi tin nhắn (Message Queue như RabbitMQ hoặc Apache Kafka) để xử lý bất đồng bộ các webhook thanh toán ngân hàng và tác vụ ghi log sự kiện người dùng (`product_views`), bảo đảm hệ thống có thể chịu tải hàng chục nghìn yêu cầu đồng thời.

CHƯƠNG 7. TÀI LIỆU THAM KHẢO

Danh mục các tài liệu khoa học, tiêu chuẩn kỹ thuật RFC và sách chuyên khảo được trích dẫn trong đồ án:

- **[1]** Fielding, R. T. (2000). Architectural Styles and the Design of Network-based Software Architectures. Doctoral dissertation, University of California, Irvine.
- **[2]** Fielding, R. T., & Reschke, J. (2014). RFC 7231: Hypertext Transfer Protocol (HTTP/1.1): Semantics and Content. Internet Engineering Task Force (IETF).
- **[3]** Jones, M., Bradley, J., & Sakimura, N. (2015). RFC 7519: JSON Web Token (JWT). Internet Engineering Task Force (IETF).
- **[4]** Nottingham, M., & Wilde, E. (2016). RFC 7807: Problem Details for HTTP APIs. Internet Engineering Task Force (IETF).
- **[5]** OWASP Foundation. (2023). OWASP API Security Top 10 2023. Open Web Application Security Project. URL: https://owasp.org/API-Security/.
- **[6]** Richardson, L., & Ruby, S. (2007). RESTful Web Services. O'Reilly Media, Inc.
- **[7]** Fowler, M. (2010). Richardson Maturity Model: steps toward the glory of REST. Martin Fowler's Bliki.
- **[8]** Agrawal, R., & Srikant, R. (1994). Fast algorithms for mining association rules in large databases. Proceedings of the 20th International Conference on Very Large Data Bases (VLDB), 487-499.
- **[9]** Manning, C. D., Raghavan, P., & Schütze, H. (2008). Introduction to Information Retrieval (Vector Space Classification & Cosine Similarity). Cambridge University Press.
- **[10]** Google Cloud Identity. (2024). OpenID Connect & OAuth 2.0 Authorization Code Flow Documentation. Google Developers Portal.

CHƯƠNG 8. PHỤ LỤC BÁO CÁO

8.1 Bảng Phân công và Mức độ Đóng góp của Thành viên

Toàn bộ các nhiệm vụ trong đồ án được phân chia công bằng theo bảng kế hoạch 4 ngày, đảm bảo mọi thành viên đều đóng góp tích cực vào cả 3 khâu: Code, Báo cáo và Video:

Bảng PL.1: Bảng phân công nhiệm vụ và tỷ lệ hoàn thành của các thành viên nhóm

Mã	Họ và tên	Phạm vi nhiệm vụ trọng tâm	Sản phẩm bàn giao	Đóng góp
TV1	Trần Hữu Nam (Leader / Back-end)	Kiến trúc REST, Bảo mật JWT/RTR, Giỏ hàng, Đặt hàng ACID, Thanh toán VietQR, Quản lý Git Flow, Biên soạn Chương 3 & 6 báo cáo.	Auth/Order/Payment APIs, Review PRs, Báo cáo Word/PDF.	100% (Hoàn thành xuất sắc)
TV2	Nguyễn Thành Trung (Back-end & Thuật toán)	Thiết kế CSDL 17 bảng, Admin APIs, Thuật toán Cosine 5D & Apriori FBT, Biên soạn Chương 2 & 4 báo cáo, Quản lý Docker/Seed.	Database Schema/Seed, Admin APIs, Similarity Engine, Video clip 2.	100% (Hoàn thành xuất sắc)
TV3	Lê Tuấn Kiệt (Front-end & UI)	Toàn bộ giao diện khách hàng & Admin (Glassmorphism), Thiết kế Design Tokens CSS, Thư viện `api.js`, Biên soạn Chương 1 & 5 báo cáo, Slide thuyết trình.	100% Giao diện UI/Admin, Bộ slide 25 trang, Video clip 3, Bug log.	100% (Hoàn thành xuất sắc)

8.2 Bảng Tra cứu Chi tiết Toàn bộ 37 Endpoints RESTful API

Bảng tổng hợp chi tiết toàn bộ các đường dẫn tài nguyên phục vụ việc kiểm thử và tích hợp hệ thống:

Bảng PL.2: Bảng tra cứu chi tiết 37 Endpoints RESTful API trong hệ thống TechStore

STT	HTTP Method	Đường dẫn tài nguyên (Resource URI)	Mô tả chức năng & Ràng buộc bảo mật
1-6	POST / GET	/api/v1/auth/register, /login, /refresh, /logout, /me, /google	Xác thực người dùng, cấp JWT, RTR, kiểm tra token, OAuth 2.0.
7-10	GET	/api/v1/products, /products/{id}, /categories, /brands	Duyệt danh sách sản phẩm có bộ lọc, chi tiết sản phẩm, danh mục, hãng.
11-14	GET / POST PUT / DELETE	/api/v1/cart, /cart/items, /cart/items/{id}, /cart	Quản lý giỏ hàng máy chủ (thêm, cập nhật số lượng, xóa món, xóa hết).
15-16	POST / GET	/api/v1/coupons/validate, /coupons	Kiểm tra mã giảm giá, áp dụng voucher, xem danh sách coupon.
17-19	POST / GET	/api/v1/orders, /orders/{id}, /orders/{id}/cancel	Tạo đơn hàng từ giỏ (ACID), xem chi tiết đơn, hủy đơn hoàn tồn kho.
20-22	POST / GET	/api/v1/payments/qr, /payments/{id}/status, /payments/webhook	Tạo mã QR VietQR MB Bank, kiểm tra trạng thái thanh toán, nhận webhook.
23-26	GET / POST DELETE	/api/v1/products/{id}/reviews, /wishlist, /wishlist/{id}	Xem và gửi đánh giá sản phẩm (1-5 sao), quản lý danh sách yêu thích.
27-29	POST / GET	/api/v1/events/view, /products/{id}/recommendations, /recommendations/me	Ghi nhận log xem, gợi ý mua kèm (Bought together), gợi ý cá nhân hóa.
30-33	POST / PUT PATCH / DELETE	/api/v1/products, /products/{id}	Admin: Thêm mới sản phẩm, sửa toàn phần, cập nhật giá/kho, xóa sản phẩm.
34-35	POST / PUT DELETE	/api/v1/categories, /categories/{id}, /brands, /brands/{id}	Admin: Quản lý danh mục ngành hàng và thương hiệu đối tác.
36	PATCH	/api/v1/orders/{id}/status	Admin: Chuyển đổi trạng thái đơn hàng (đang giao, đã giao, hủy đơn).
37	GET / PATCH	/api/v1/admin/users, /admin/stats, /admin/audit-logs	Admin: Phân quyền tài khoản, xem thống kê KPI doanh thu 7 ngày, xem nhật ký kiểm toán.